

LAB 03

NextCorp - ISO 27001 İç Denetimi

Zorluk: Orta • Tahmini süre: 30-60 dakika • Rolünüz: ISO 27001 Internal Auditor

1. HİKÂYE

Sektör Kurumsal yazılım	Ölçek 780 çalışan, 6 ülke
BT ortamı Azure, M365, şirket içi ERP, uzaktan çalışma	Hedef Dört ay sonra ISO 27001 belgelendirme denetimi

NextCorp iki yıl önce bir BGYS kurmuş ve temel politika setini yayımlamıştır. Yönetim, belgelendirme denetimine hazır olduğunu düşünmektedir. Ancak son yeniden yapılanmada Bilgi Güvenliği Yöneticisi değişmiş, bazı kontrol sahipleri güncellenmemiştir. Siz yıllık iç denetimi yürütmek ve yönetimin gözden geçirmesi öncesinde kanıta dayalı bir rapor sunmakla görevlendirildiniz. Kapsam; ürün geliştirme, bulut altyapısı, insan kaynakları ve destek operasyonlarıdır.

2. SİZE VERİLEN GÖREV

Politika varlığını tek başına yeterli kabul etmeden, seçilen BGYS süreçlerinin uygulanmasını ve tutarlılığını değerlendirin. Uygunsuzluk sınıflandırması için kapsam ve yaygınlık kanıtını dikkate alın.

3. OLAYLAR VE KANITLAR

E-01 | BGYS kapsamı v3.0
'NextCorp Türkiye ofisi, Azure üretim ortamı ve yazılım geliştirme faaliyetleri.' Polonya destek ekibi müşteri kayıtlarına erişmektedir ancak kapsam şemasında yer almamaktadır.

E-02 | Risk değerlendirme prosedürü
Riskler yılda en az bir kez ve önemli değişikliklerde gözden geçirilir. Risk kayıt defterinin son tam onayı 14 ay öncedir. Yeni yapay zekâ destek özelliği üç ay önce canlıya alınmıştır.

E-03 | Uygulanabilirlik Bildirgesi
SoA v2.1'de 93 kontrolün 88'i uygulanabilir gösterilmiştir. Beş hariç tutma gerekçelidir. DLP kontrolü 'uygulanıyor' görünür; M365 yönetim ekranında politika pilot modundadır.

E-04 | Farkındalık kayıtları
Çalışanların %96'sı yıllık eğitimi tamamlamıştır. Yeni başlayan 31 kişiden 7'si 30 günlük hedefi aşmıştır. İK, yoğun işe alım döneminde hatırlatmaların geciktiğini söylemiştir.

LAB 03

NextCorp - ISO 27001 İç Denetimi

Zorluk: Orta • Tahmini süre: 30-60 dakika • Rolünüz: ISO 27001 Internal Auditor

3. OLAYLAR VE KANITLAR - DEVAM

E-05 | İç denetim programı

Program yılda bir denetim öngörmektedir. Geçen yılın iki bulgusu kapalıdır. Erişim review bulgusunun kapanış kanıtı yalnızca süreç sahibinin 'tamamlandı' e-postasıdır.

E-06 | Olay kayıtları

Son 12 ayda 18 düşük, 3 orta olay vardır. Olayların tümü zamanında kapatılmıştır. Üç orta olay için lessons learned toplantısı planlanmış fakat tutanak bulunamamıştır.

E-07 | Yönetici görüşmesi

CTO: 'Politikalarımız denetime hazır. Pilot DLP de teknik olarak devrede sayılır.' BGYS yöneticisi: 'Kontrolün uygulanıyor sayılması için enforcement moduna geçmesi gerektiğini düşünüyorum.'

4. ÖĞRENCİNİN GÖREVLERİ

- BGYS kapsamındaki olası tutarsızlıkları değerlendirin.
- Risk değerlendirmesinin güncelliğine ilişkin sonuca varmak için ek kanıt belirleyin.
- SoA ile teknik uygulama arasındaki farkı nasıl sınıflandıracağınızı açıklayın.
- Önceki bulgu kapanış kanıtının yeterliliğini tartışın.
- Her gözlem için uygunsuzluk, iyileştirme fırsatı veya uygunluk değerlendirmesi yapın.
- En önemli gözlem için kök neden ve düzeltici faaliyet beklentisi yazın.

5. TESLİM EDİLMESİ BEKLENEN ÇIKTI

- Kapsam ve risk değerlendirme notu
- En az 4 denetim gözlemi
- Kanıt yeterliliği değerlendirmesi
- 1 profesyonel uygunsuzluk metni
- Yönetimin gözden geçirmesine özet

ÇALIŞMANIZI TAMAMLADINIZ MI?

Bu vaka çalışmasının tek bir doğru cevabı olmayabilir. Önemli olan; riskleri nasıl değerlendirdiğiniz, kanıtları nasıl yorumladığınız ve vardığınız sonucu nasıl savunduğunuzdur.

Çalışmanızı tamamladıktan sonra çıktınızı:

volkan@grcustasi.com
adresine gönderebilirsiniz.

Gönderdiğiniz çalışmayı inceleyerek size geri dönüş sağlayacağım.

- Volkan Güler, CISA, CISM
GRC Ustası